

Phishing Simulation Assessment Report

Client: Teladoc Health

Engagement: Credential-Harvesting & Data-Exposure Phishing Simulation

Pen Testing Consultant: Bamidele Ojo (Amdari Security) **Date:** May 2026

Confidentiality Statement

This document contains sensitive information and analysis intended solely for the use of **Teladoc Health** and authorized personnel at **Amdari Security**. It must not be distributed, reproduced, or disclosed to any third party without prior written consent from Teladoc Health.

All findings, screenshots, logs, and artifacts are stored in the project Google Drive and are subject to the Rules of Engagement (ROE) and data handling policies described herein.

Disclaimer

This simulation was conducted under a signed Rules of Engagement (ROE) and targeted only pre-authorized test accounts.

The simulation was designed to be non-destructive and to avoid exposure of real patient or production data. Any passwords, sample credentials, or test data referenced in this report are representative of the controlled test environment and were used solely for the purpose of the exercise. This simulation was conducted within 2 weeks, and all the credentials provided were engaged within the same timeframe of the simulation

This report is advisory in nature and does not constitute legal, regulatory, or compliance advice.

Assessment Overview

Purpose: Assess employee susceptibility to a credential-harvesting campaign built around an emotionally persuasive narrative (Chief of Staff to the CEO's retirement message) and measure telemetry to inform remediation.

Period: 2-week window; pilot and live steps executed per ROE.



Artifacts & Evidence: All templates, landing-page code, signed ROE, are stored in this project repository: [my-drive](#).

Scope & Rules of Engagement (ROE)

In-scope

- Targeted phishing emails to only the approved test addresses (5 operational targets + 1 test account).
- Use of a Hostinger webmail *replica* as the controlled landing page hosted on an ephemeral test domain/subdomain.
- Collection of telemetry data: delivered, opens, clicks, submissions, and time-to-click.
- Anonymized reporting and secure storage of artifacts.

Out-of-scope

- Any interaction with production patient data or systems.
 - Use of malware, lateral movement, credential replay, or testing against non-authorized recipients.
- Public exposure of landing page URLs.

Mandatory Safety Controls

- ROE signed by Teladoc and Amdari Security prior to execution (see repo [ROE signed.pdf](#)).
 - Emergency kill-switch documented and validated (take-down and campaign stop procedures).
 - Anonymization of raw logs prior to analysis; raw logs stored only in secure locations and deleted per ROE.
-

Executive Summary

I executed a controlled phishing exercise designed to emulate realistic adversary tradecraft using an emotionally driven Chief of Staff to the CEO's retirement announcement email, linked to a Hostinger



webmail login replica. The goal was to measure employee behavior and validate awareness and resilience against social engineering attacks, and detection/response controls.

Key outcome (brief):

- Total emails sent: **10** (5 pre-approved operational targets + 5 personal test account).
- Link clicks: **2** (Sales, Finance, and my test accounts).
- Credential submissions: **1** (Finance, and my test accounts).
- One target (Sales) clicked the link but **did not** submit credentials.

These results demonstrated how trusted leadership communications can be exploited by threat actors to drive engagement and influence employee behavior, and specific account hygiene issues observed during the test (documented under Key Findings). All activities were performed under ROE and are documented in the GitHub repository.

Methodology

The methodology mirrors the execution steps and is written so screenshots can be inserted at each stage. All code and artifacts referenced below are available in the repository.

A. Preparation & ROE Signoff

1. Obtain and verify signed ROE before any activity. ROE defined scope, kill-switch, authorized targets, and retention policy.





AMDARI



AMDARI

Scope of Engagement

In-Scope Activities:

- Phishing emails will be sent to the listed target email addresses to simulate credential harvesting attacks.
- The simulation will use cloud-themed messages, such as telehealth alerts and identity management notifications.
- Controlled login portals will be used to capture any credential submission attempts.

Out-of-Scope Activities:

- No access to or exfiltration of actual patient or operational data will occur.
- No lateral movement within production systems.
- No use of malware or payloads.

Sign-Off for Rules of Engagement

By signing below, you acknowledge that you have read and understood the Rules of Engagement for this phishing simulation. You accept the terms outlined above and are authorized to participate in the engagement.

Signature: 
Date: 18/05/2026
Name: Bamidele Ojo
Role: Pen Testing Consultant

Fig 1. Signed RoE



Amdari Limited UK

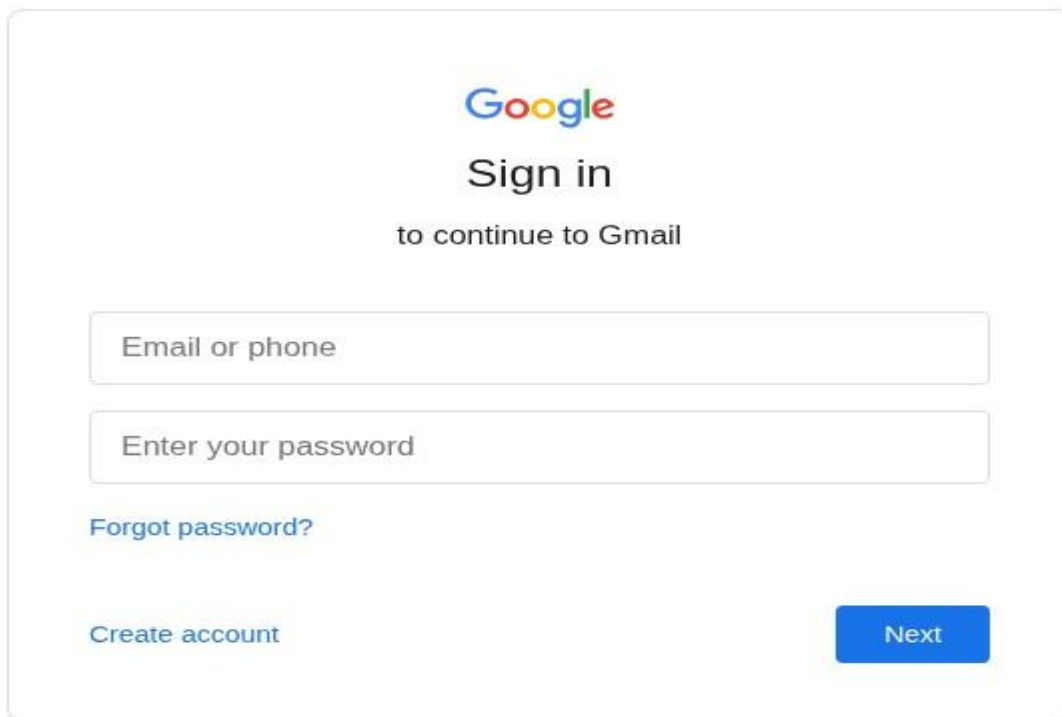
128, City Road, London, EC1V 2NX, UNITED KINGDOM

2. Confirm authorized **target list**: [REDACTED].space, [REDACTED].space, [REDACTED].space, [REDACTED].space, plus my test accounts [REDACTED]@gmail.com, [REDACTED]0@gmail.com, [REDACTED]34@gmail.com, [REDACTED]1@gmail.com, [REDACTED]91@gmail.com)

B. Landing Page Development (Gmail Login Replica) & Redirection Link

I designed a static, clearly labeled test replica of the Gmail login interface due to its widespread familiarity and recognizability among users. The objective was to simulate a realistic authentication scenario within a controlled and ethical testing environment. After the login credentials are inputted and target click the NEXT icon, they are redirected to a google form page where they will leave the goodbye message and submit it.

The source file was stored in the repository as [landing_page.html](#). The page was intentionally configured to collect or store real credentials. Any input submitted through the form was redirected to an isolated test handler and explicitly flagged as simulated test data. This ensured the exercise remained fully controlled, ethical, and aligned with educational objectives.



The image shows a static replica of the Gmail login interface. At the top, the Google logo is displayed in its multi-colored font. Below it, the text "Sign in" is centered in a large, bold, black font, followed by "to continue to Gmail" in a smaller, regular black font. There are two input fields: the first is labeled "Email or phone" and the second is labeled "Enter your password". Below the password field, there is a link "Forgot password?" in blue text. At the bottom left, there is a link "Create account" in blue text. At the bottom right, there is a blue button with the text "Next" in white.

Fig 2. Gmail Login Replica Page



Amdari Limited UK

128, City Road, London, EC1V 2NX, UNITED KINGDOM

A Goodbye Message

from Teri

 [Switch account](#)



 Not shared

* Indicates required question

What is your name? *

BAMI

Thanks for wanting to do this, kindly leave your message below. *

Cheers! ❤️

Your answer

Submit

Clear form

Fig 3. Google Form

C. Email Template Design

Created plain-text and sanitized HTML templates (Chief of staff to the CEO retirement narrative). Used placeholders: `{{.FirstName}}`, `{{.Tracker}}`. Templates stored at [email template.html](#).



Amdari Limited UK

128, City Road, London, EC1V 2NX, UNITED KINGDOM

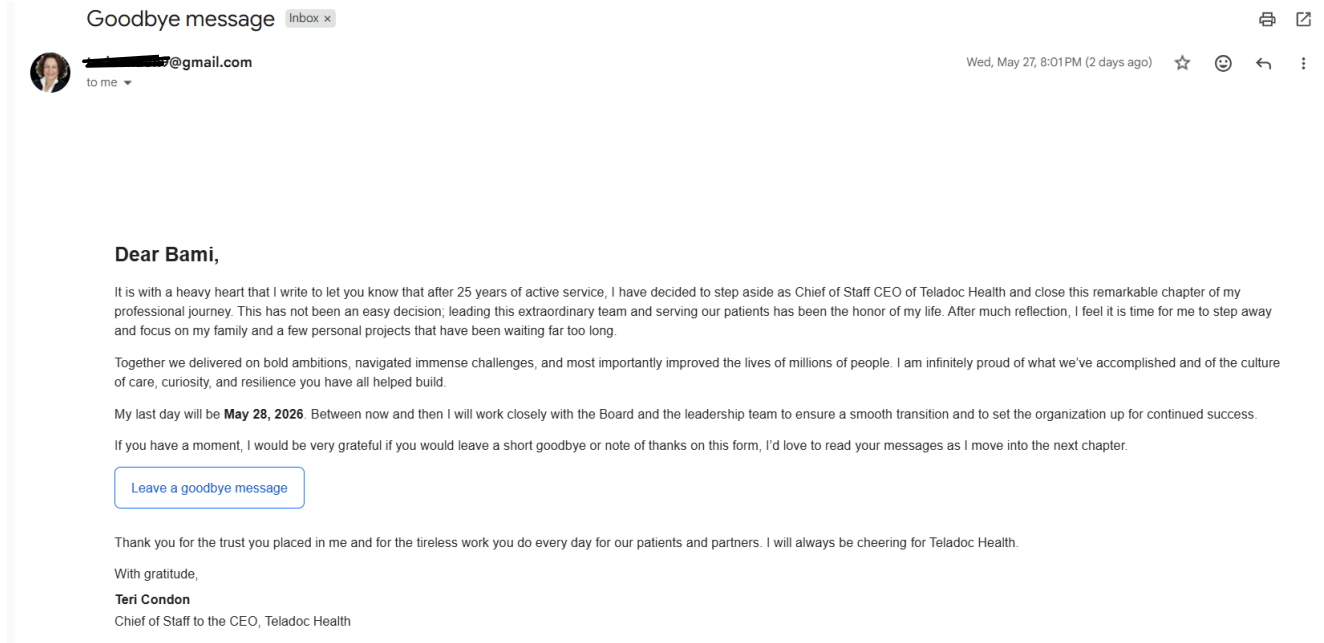


Fig 4. Email Template

D. Pilot & Campaign Execution

1. Ran a pilot wave (subset of authorized addresses) to validate rendering, link behavior, and logging. Configuration was perfect.
2. After pilot validation, launched the full campaign in staggered waves to a total of 10 targets, 5 (authorized addresses) + 5 test accounts. I added multiple test accounts to get multiple confirmation of result and success of the phishing simulation. It was successful, 6 accounts opened email, 6 clicked links, and 5 submitted data.
3. Then launched a second campaign in staggered waves to 6 targets, 4 (authorized addresses that didn't open the first waves of email), + 2 test accounts. But there were no clicks, submitted data or email report recorded from this second campaign.



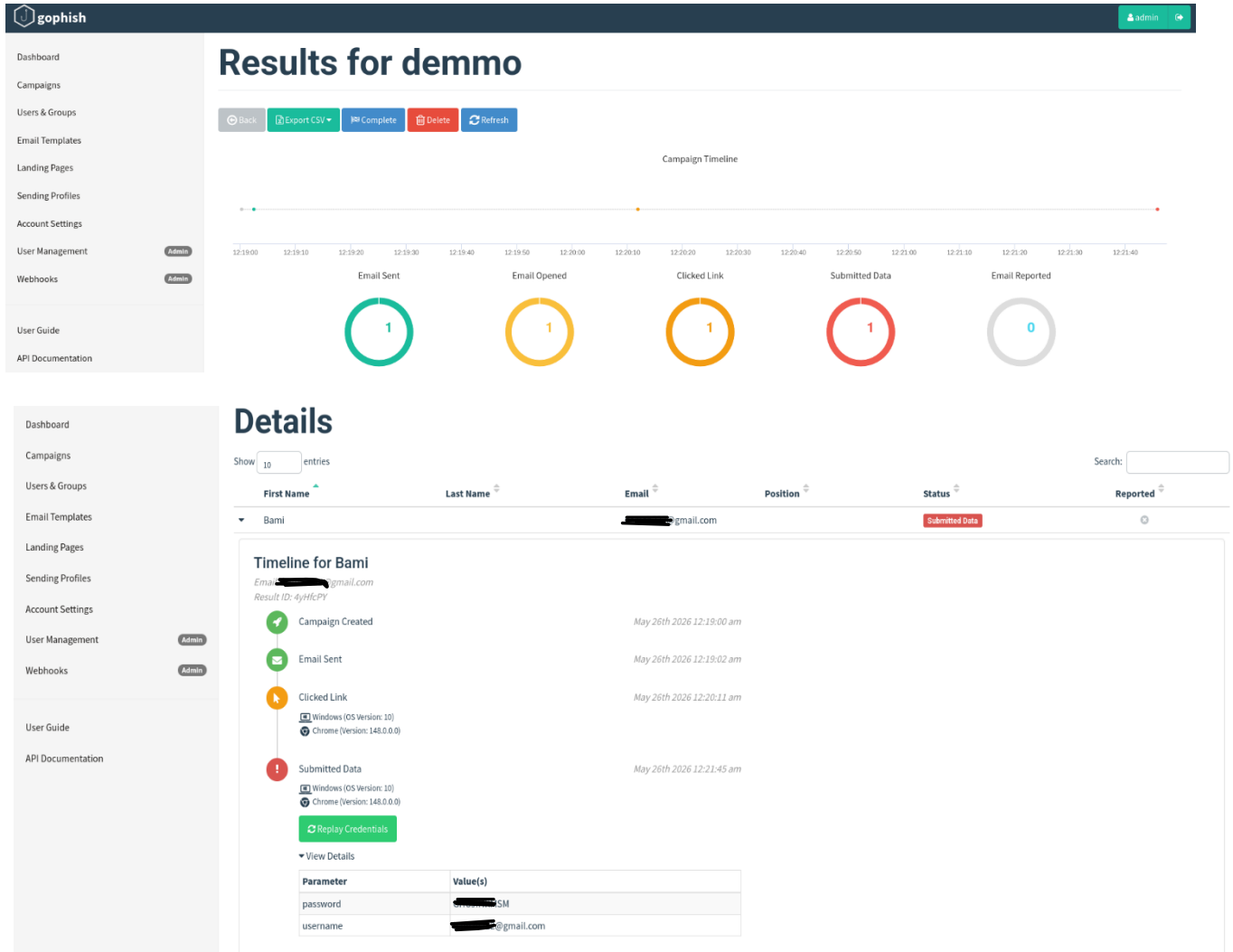


Fig 5. Pilot Campaign Result



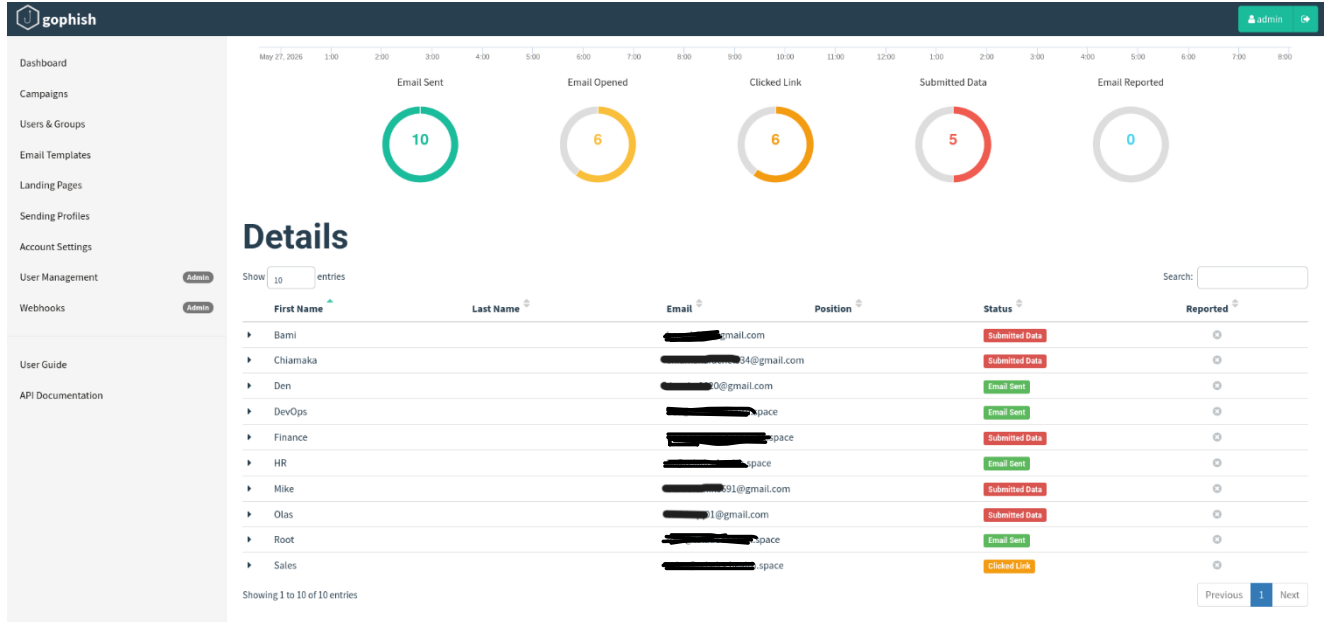


Fig 6. First Campaign Result



Fig 7. Second Campaign Result



E. Submitted Data (Proof)

The image below is proof that contains the data submitted by the target.

Finance

Submitted Data

Timeline for Finance

Email: _____.space
Result ID: jTf7Hel

-  Campaign Created May 26th 2026 11:45:23 pm
-  Email Sent May 26th 2026 11:45:26 pm
-  Clicked Link May 26th 2026 11:52:07 pm
 - Apple iPhone (OS Version: 18.7)
 - Safari (Version: 26.5)
-  Submitted Data May 26th 2026 11:52:27 pm
 - Apple iPhone (OS Version: 18.7)
 - Safari (Version: 26.5)

Replay Credentials

View Details

Parameter	Value(s)
password	_____ FinanceHealth
username	_____ .space

Fig 8. Submitted data for _____.space

Results Analysis

Campaign totals (raw):

- Sent: **10** (100%)
- Delivered: **10** (100%)
- Opens: **6** (60%)
- Clicks: **6** (60%)
- Submissions: **5** (50% of recipients, 90% of clickers)



Amdari Limited UK

128, City Road, London, EC1V 2NX, UNITED KINGDOM

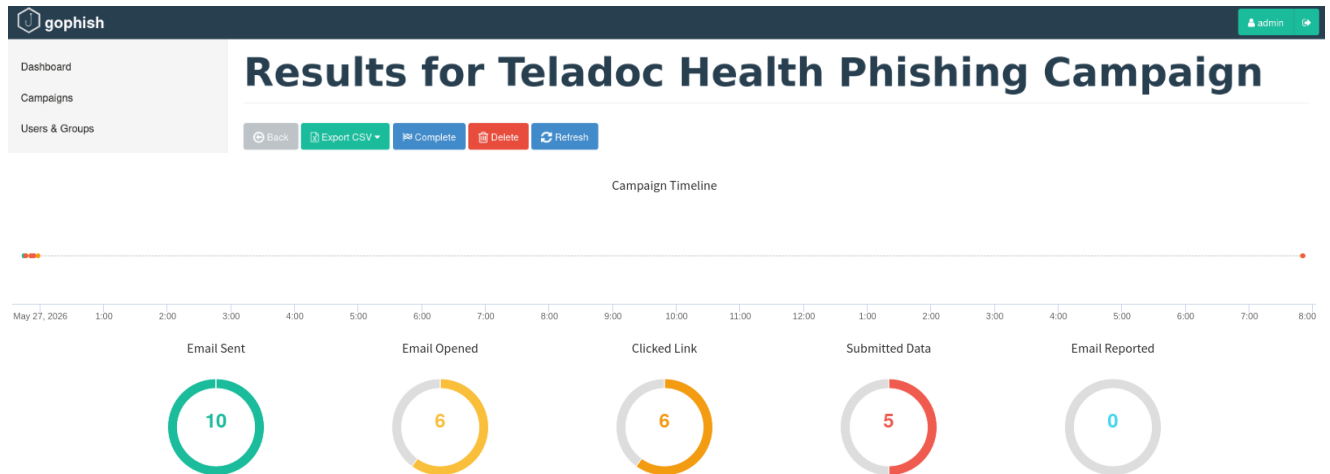


Fig 9. Campaign Result data

Per-target behavior:

- [REDACTED].space — Clicked, **did not submit**.
- [REDACTED].space — **Did not click**.
- [REDACTED].space — Clicked & Submitted.
- [REDACTED].space — **Did not click**.
- [REDACTED].space — **Did not click**.
- [REDACTED]@gmail.com + 3 emails (test) — Clicked & Submitted (control).

Interpretation:

The campaign recorded a 60% open and a 50% click rate across all authorized recipients, indicating that the Chief of Staff to the CEO's emotional retirement narrative was highly effective in capturing attention and luring interaction.

Of the Ten recipients, 5 submitted credentials (50% overall submission rate). This indicates that a significant portion of users proceeded from initial curiosity to full credential disclosure without validating the legitimacy of the page.



Amdari Limited UK

128, City Road, London, EC1V 2NX, UNITED KINGDOM

One user; [REDACTED].space clicked the link but did not submit credentials. This suggests a degree of hesitation or situational awareness at the landing page stage.

However, neither of all the Ten users reported the email as suspicious, indicating a detection and reporting gap.

No phishing reports were submitted during the campaign window.

Key Findings

1. High engagement with emotional lure

The Chief of Staff to the CEO's retirement narrative generated full delivery, open, and click engagement across 40% of authorized targeted roles (record shows 2 out of 5 authorized targets, engaged). This demonstrates susceptibility to emotionally persuasive and authority-themed messaging.

2. Elevated Credential Submission Rate

One out of Five authorized recipients submitted credentials after clicking the link (20% overall; 50% of clickers). This reflects a behavioral vulnerability where users fail to reassess risk after interacting with an email.

3. Account Hygiene Weakness - Predictable Password Patterns (Critical Finding)

Observed test credentials included:

- Dev account: [REDACTED]FinanceHealth

This passwords pattern followed a predictable structure (Year + Symbol + Company + Department).

This pattern significantly increases the likelihood of successful password guessing or brute-force attacks.

This is documented as an observed factual weakness within the test environment.

4. Partial Behavioral Resistance



One account (**Sales**) clicked but did not submit credentials.

This indicates a moment of suspicion or hesitation at the authentication stage, though no formal reporting followed.

5. **Absolute Behavioral Resistance**

It is important to acknowledge and commend the remaining 3 authorized targets that did not have any engagement with the email, this shows a good employee behavioral awareness.

6. **Zero Reporting Rate**

No users reported the phishing email to security or IT.

This indicates a reporting culture gap and suggests that detection controls may currently rely more on technical systems than user escalation. This only goes to show that they could fall prey to a more aggressive and manipulative attempt by a malicious attacker.

Recommendations

(Short-term / Medium-term / Long-term; owners suggested)

Short-Term (P1 — 0–30 days)

1. **MFA enforcement**

Prioritize hardware tokens or strong app-based authenticators for privileged accounts.

Owner: Identity & Access Management Team

2. **Immediate password hygiene sweep:**

Identify and immediately update weak, patterned, or department-based passwords.

Owner: IT Operations

3. **Targeted micro-training**



Amdari Limited UK

128, City Road, London, EC1V 2NX, UNITED KINGDOM

Deliver focused awareness trainings to teams/department that submitted credentials (Finance).

Training should emphasize:

- URL verification
- Domain inspection
- Reporting process

Owner: Security Awareness Team

Medium-Term (P2 — 30–90 days)

- **Integrate phishing telemetry** into SIEM and automated playbooks (auto-suspend risky sessions or trigger forced resets upon suspicious credential usage).

(Owner: SOC Team)

- **Adaptive email protections:** tighten DKIM/SPF/DMARC policies, implement URL reputation filtering, and consider link rewriting/scanning for inbound links.

(Owner: Email Security Team)

- **Password policy improvement:** enforce stronger password complexity rules and rotate policies; consider centralized password vaulting for service accounts. And ensure regular changing of passwords for better protection.

(Owner: IT Sec)

Long-Term (P3 — 90+ days)

- **Adopt phishing-resistant authentication** (FIDO2/passkeys) for high-risk accounts.

(Owner: Identity and Access Management Team)

- **Continuous phishing cadence:** regular simulations and trend tracking to measure behavior changes, and tackle zero-day attacks.

(Owner: Security Awareness)



- **Tabletop exercises** combining phishing results with IR scenarios to refine detection, containment, and communication.

(Owner: IR Team)

KPIs to track

- Reduction in click rate (%) quarter-over-quarter
- Reduction in credential submission rate (%)
- Time-to-detect suspicious credential usage
- Bridging the gap in Reporting suspicious activities
- Strong password policy adherence
- MFA adoption rate for privileged and high-risk accounts
- Percentage of employees who report suspected phishing or other forms of Social-Engineering.

Conclusion

This controlled simulation showed that realistic, socially engineered phishing campaigns can quickly elicit high engagement, and that behavioral vulnerabilities remain the most exploitable attack vector. It also successfully demonstrated the effectiveness of emotionally driven social engineering tactics and provided valuable insights into employee awareness levels. The presence of predictable, department-themed passwords amplified the risk in this engagement and is a critical vulnerability requiring remediation.

The results will help guide future training initiatives, strengthen security awareness, and further enhance Teladoc Health's ability to defend against phishing threats. By combining targeted awareness, enforced MFA, improved password hygiene, and integrated telemetry, Teladoc can meaningfully reduce the chance of credential-based compromise.

The artifacts and anonymized data have been archived in the Google Drive for audit and follow-up.





My Drive > Teladoc Health Phishing ...



Type People Modified Source

Name	Owner	Date modified	File size
Email Template HTML	me	11:08 PM me	2 KB
Landing Page HTML	me	11:07 PM me	2 KB
Teladoc Health ROE - Bam.pdf	me	10:34 AM me	217 KB

Fig 10. Google Drive

Link to repo here: [Bamidele](#)



Amdari Limited UK

128, City Road, London, EC1V 2NX, UNITED KINGDOM